GOBERNANZA CORPORATIVA & SEGURIDAD DE LA INFORMACIÓN

Memorándum Normativo: Política de Seguridad & Resiliencia Edge

Directrices Obligatorias de Cero Confianza (*Zero Trust*), Gestión de Acceso Remoto, Protección de Datos Sensibles y Régimen de Cumplimiento Operacional.

ENCABEZADO OFICIAL DE MEMORÁNDUM

DE:	Dirección General de Cumplimiento, Riesgo Operacional & Ciberseguridad
PARA:	Toda la Organización, Filiales del Grupo, Colaboradores y Contratistas
CC:	Directorio Corporativo, Auditoría Interna, Gerencias de Área
FECHA:	03 de Noviembre de 2026
REF:	Directiva de Gobernanza Tecnológica y Protección de Activos Críticos
CLASIFICACIÓN:	**VINCULANTE / OBSERVANCIA GENERAL OBLIGATORIA**

HISTORIAL DE CONTROL DE VERSIONES DEL DOCUMENTO

Versión	Fecha	Autor / Cargo	Resumen del Cambio Normativo
v1.0	12/01/2024	CISO Corporativo	Emisión base de política de seguridad de endpoints.
v2.0	20/05/2025	Dirección TI	Inclusión de directrices de telemetría y nodos IoT.
v3.0	03/11/2026	Oficial de Cumplimiento	Actualización obligatoria a arquitectura *Zero Trust* y mTLS.

BNW Corporate Group S.A. – Circular de Aplicación General.

El desconocimiento de esta norma no exime de su estricto cumplimiento.

1 Objetivo, Alcance Normativo y Aplicabilidad

El propósito del presente memorándum normativo es establecer el marco regulatorio obligatorio para la protección de los activos digitales, bases de datos de clientes, interfaces transaccionales y equipamiento de borde pertenecientes a **BNW Corporate Group S.A.** o administrados por sus filiales.

1.1 Ámbito de Aplicación Universal

Las disposiciones aquí contenidas revisten carácter vinculante e inexcusable para:

- **Personal de Planta y Contratistas**: Empleados directos, personal eventual, consultores y prestadores de servicios que interactúen con los sistemas de la compañía.
- **Infraestructura y Nodos**: Servidores en nube pública o privada, estaciones edge, datacenters y dispositivos periféricos.
- **Ciclo de Vida de los Datos**: Información en tránsito, datos en procesamiento y almacenamiento en reposo.

2 Directrices Obligatorias de Ciberseguridad y Operación

DIRECTRIZ NORMATIVA 01: AUTENTICACIÓN FUERTE (MFA) Y GESTIÓN DE IDENTIDADES

1. **Factor Múltiple Mandatorio**: Todo acceso a cuentas corporativas (correo, VPN, SSH, consolas cloud y ERP) exige autenticación MFA vía llave física FIDO2 o token temporal TOTP. Queda vetado el uso de SMS como segundo factor.
2. **Complejidad de Claves**: Longitud mínima de 16 caracteres alfanuméricos y símbolos. Rotación obligatoria cada 90 días.
3. **Prohibición de Cuentas Compartidas**: Se prohibe terminantemente el uso compartido de contraseñas de administración. Toda acción privilegiada debe ser trazable a una identidad nominal e intransferible.

DIRECTRIZ NORMATIVA 02: ARQUITECTURA CERO CONFIANZA (*ZERO TRUST*) EN EL BORDE

1. **Segregación Estricta de Redes**: La red operativa de concentradores edge (OT) permanecerá física y lógicamente aislada de la red administrativa corporativa (IT) mediante firewalls de inspección profunda (NGFW).
2. **Cifrado mTLS Obligatorio**: Ningún nodo o microservicio procesará peticiones no autenticadas con certificados de cliente firmados por la Autoridad Certificadora (CA) raíz interna.
3. **Mínimo Privilegio (PoLP)**: Los accesos administrativos a servidores se concederán bajo demanda (*Just-in-Time*) por lapsos no mayores a 4 horas.

3 Prohibiciones Expresas y Acciones Vetadas

PROHIBICIONES TAXATIVAS Y VULNERACIONES SEVERAS

Quedan terminantemente prohibidas en toda la organización las siguientes conductas:

- **Dispositivos No Autorizados**: Conectar equipos personales (BYOD) o memorias USB sin autorización previa y análisis forense del Área de Seguridad TI.
- **Extracción de Información**: Almacenar código fuente, bases de datos o credenciales en servicios de nube pública personales (Google Drive, Dropbox, repositorios Git públicos).
- **Desactivación de Agentes**: Inhabilitar, modificar o alterar los agentes corporativos de antivirus, EDR (*Endpoint Detection and Response*) o telemetría de auditoría.
- **Credenciales en Código**: Subir claves de API, secretos de bases de datos o llaves criptográficas a repositorios de versiones sin herramientas de enmascaramiento (*git-secrets*).

PROCEDIMIENTO EXCEPCIONAL DE DISPENSA NORMATIVA

Cualquier excepción temporal a las directrices de esta política deberá ser solicitada formalmente vía formulario de mitigación de riesgos, requiriendo firma conjunta del CISO y del Gerente del Área solicitante, con vigencia máxima de 30 días no prorrogables sin reevaluación presencial.

4 Protocolo Mandatorio de Reporte de Incidentes

Cualquier colaboradora o colaborador que detecte o sospeche una anomalía de seguridad (intento de *phishing*, tráfico anómalo de red, pérdida de equipo móvil corporativo o filtración de claves) debe activar el protocolo de emergencia:

Nivel	Tipo de Incidente	Canal de Activación	Ventana Máxima de Reporte
P1	Ataque activo / Filtración	Línea de Emergencia SOC	**Inmediato (< 15 minutos)**
P2	Mal funcionamiento EDR	Ticket Urgente Service Desk	**Menor a 60 minutos**
P3	Correo sospechoso	Botón PhishAlarm en Outlook	**Menor a 4 horas**

5 Régimen Sancionatorio y Consecuencias Disciplinarias

El cumplimiento de esta circular es obligatorio y fiscalizable permanentemente. La inobservancia o negligencia frente a los estándares establecidos será calificada según su gravedad:

Gravedad	Tipificación de la Falta	Medida Disciplinaria Aplicable
Leve	Descuido en bloqueo de pantalla o retraso en rotación de clave.	Amonestación verbal y reentrenamiento obligatorio en seguridad.
Grave	Uso de credenciales compartidas o conexión de equipos no autorizados.	Amonestación escrita con copia a la autoridad laboral y suspensión.
Gravísima	Fuga deliberada de datos, sabotaje o desactivación de controles.	Término inmediato del contrato sin indemnización y querella penal.

Nota Legal: Sin perjuicio de las medidas internas, la compañía ejercerá las acciones indemnizatorias y penales pertinentes al amparo de la legislación vigente de Delitos Informáticos y Protección de Datos Personales.

6 Vigencia, Derogaciones y Canales de Consulta

- **Vigencia Inmediata**: Rige a partir de las 00:00 horas del día de su publicación oficial.
- **Efecto Derogatorio**: Deja sin efecto y deroga las circulares internas `CIR-2024-02` y `CIR-2025-08`.
- **Canal de Denuncia Ética**: Buzón confidencial e independiente en: `www.grupobnw.com/canal-etico`

Dr. Gonzalo A. Valenzuela R.
Oficial Corporativo de Cumplimiento & CISO
BNW Corporate Group S.A.

Ignacio V. Bravo M.
Gerente General & Representante Legal
BNW Corporate Group S.A.

```
SELLO DIGITAL CRIPTOGRAFICO BNW TRUST NETWORK (2PC-VERIFIED)
SHA-256:  9c4b72ef1a08412e87d03923a411bc40e74f881290bb341fa502e617d58a94cb
TIMESTAMP: 2026-11-03 17:00:00 UTC - EMISOR: BNW Corporate Group Governance Policy Ledger -
ESTADO: CONCILIADO
```